RBAC: componentes, UX, accesibilidad y movilidad

Segunda evaluación parcial · defensa con el prototipo navegable

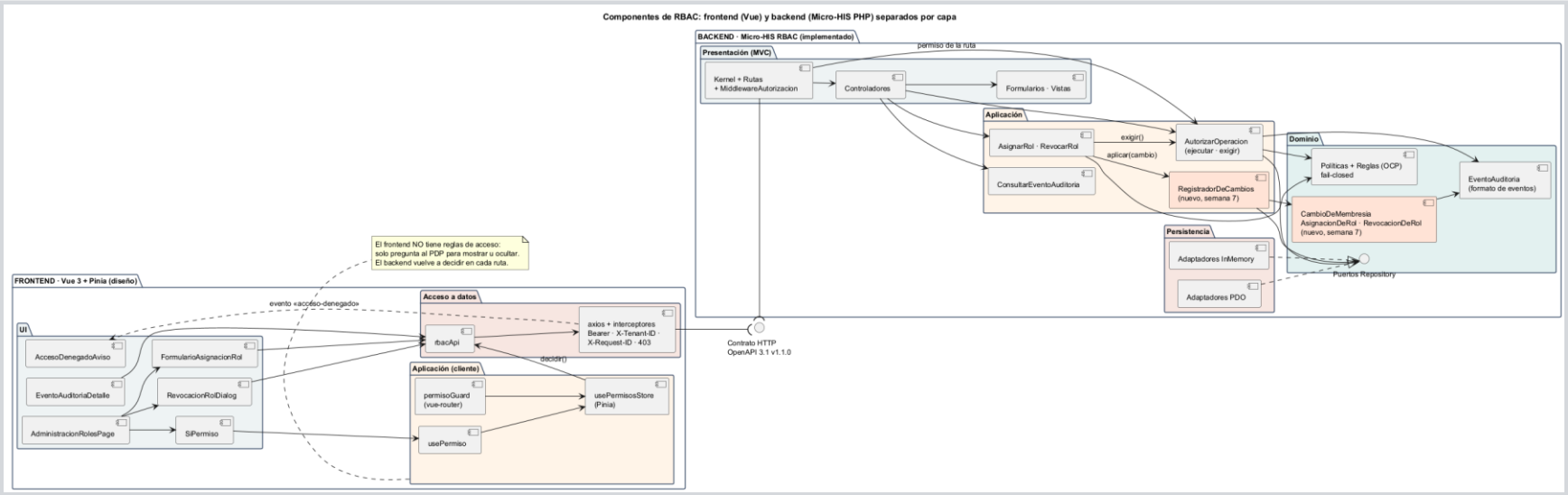
Boris Alexander Quiroa Orellana · Análisis de Sistemas II 2026

42/42
comprobaciones del recorrido (escritorio + móvil)

38/38
paridad prototipo ↔ backend real

9 → 0
denegaciones «fantasma» (cambio)

Componentes: la interfaz no decide

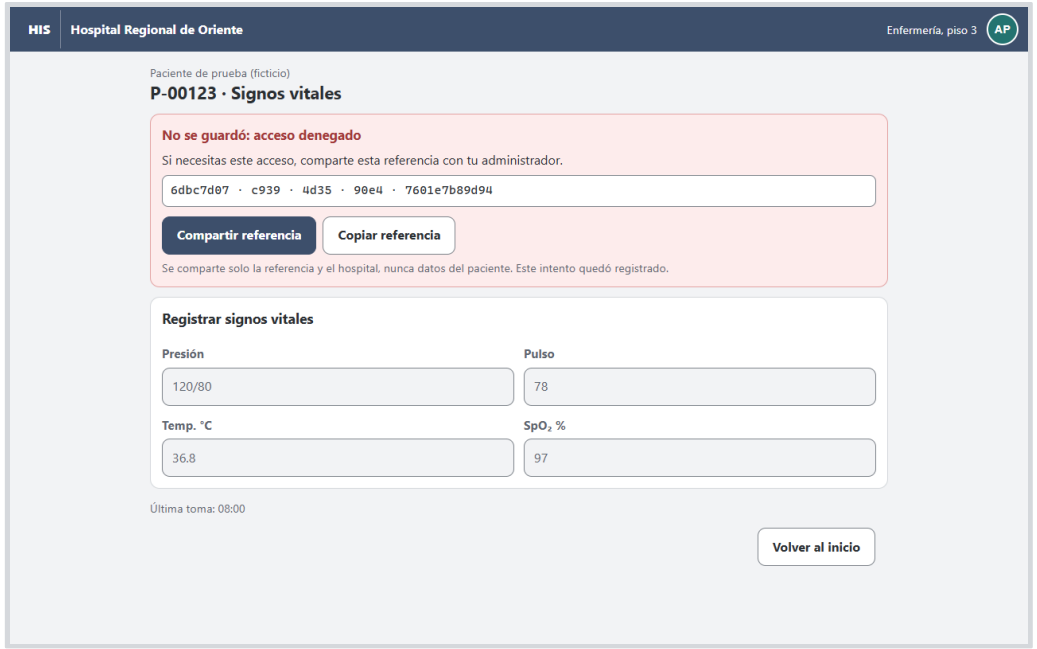


Mostrar: SiPermiso / guard preguntan qué mostrar; nunca ejecutan nada (D-18, D-31).

Decidir: Cada operación se re-autoriza en el servidor: Ana ve «Guardar» y recibe 403 (EC-4).

Refactor: CambioDeMembresia + RegistradorDeCambios: Ce de AsignarRol 13 → 8 (D-19).

UX: denegar sin revelar, siempre con una salida



- **403 sin motivo** ni rol ni permiso (R-08); referencia + Compartir/Copiar
- **Mensajes M-xx** cada uno ligado a un código real del backend
- **Confirmar con nombre** y permisos antes de asignar (H-01 → BL-01)
- **Revocar** en diálogo destructivo: motivo ≥ 10, casilla, foco en Cancelar
- **Compartir** solo referencia y hospital, nunca datos del paciente

RNF-10 · D-20, D-21, D-22, D-23

Accesibilidad: evaluada, corregida y medida

93

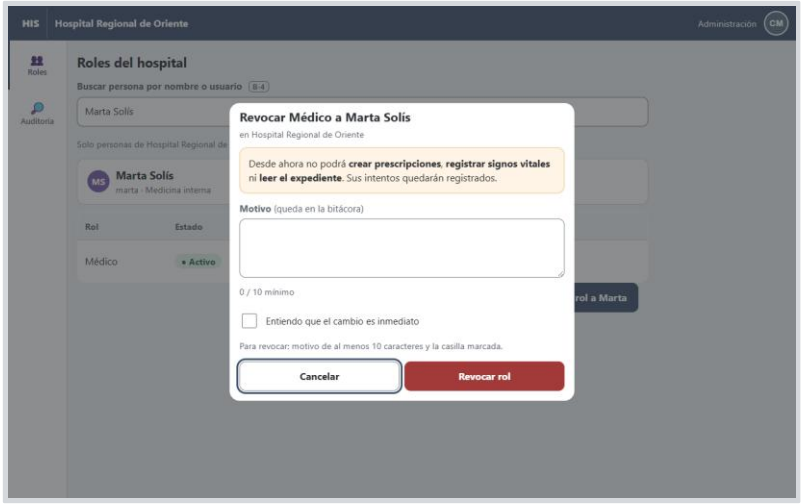
ítems de checklist: Nielsen + WCAG 2.2 + RBAC (S9)

0

infracciones axe en 32 pantallas (S11–S12)

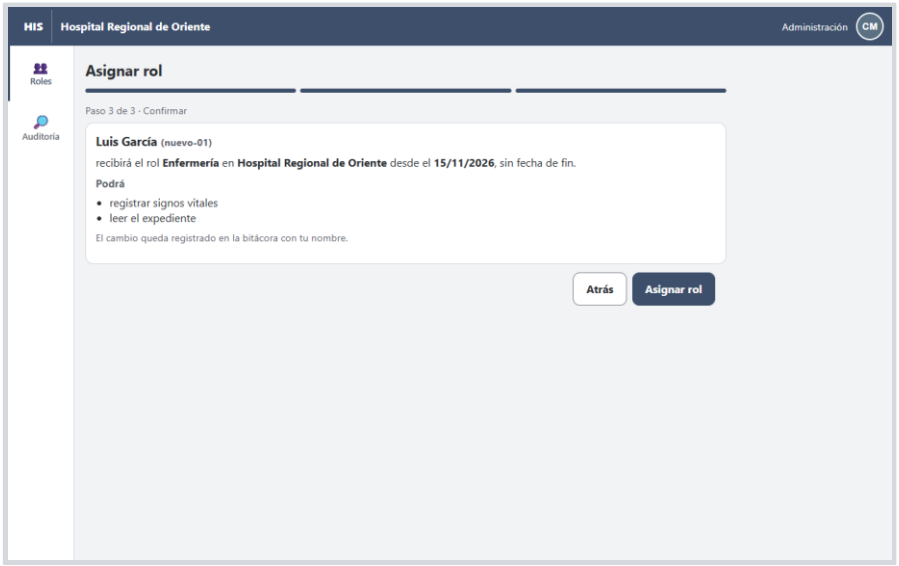
44 px

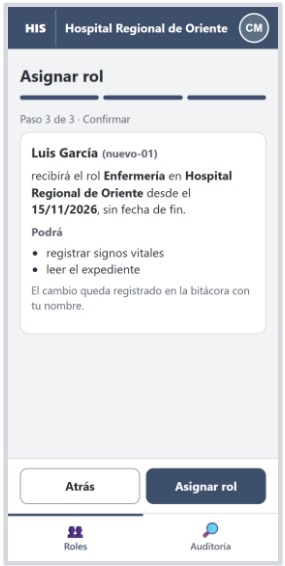
objetivo táctil mínimo; campos ≥ 16 px



- **Teclado:** foco inicial en Cancelar, Tab no sale del diálogo, Esc devuelve el foco
- **Revocación** completa solo con teclado (TEC-2)
- **Primera corrida:** 24 fallas (contraste, ARIA, 44 px) → corregidas → 0
- **Contraste** medido con script: gris #8A8F96 (3.26:1) → #5F6670 (5.80:1)

Movilidad: una sola app, de 320 px a escritorio

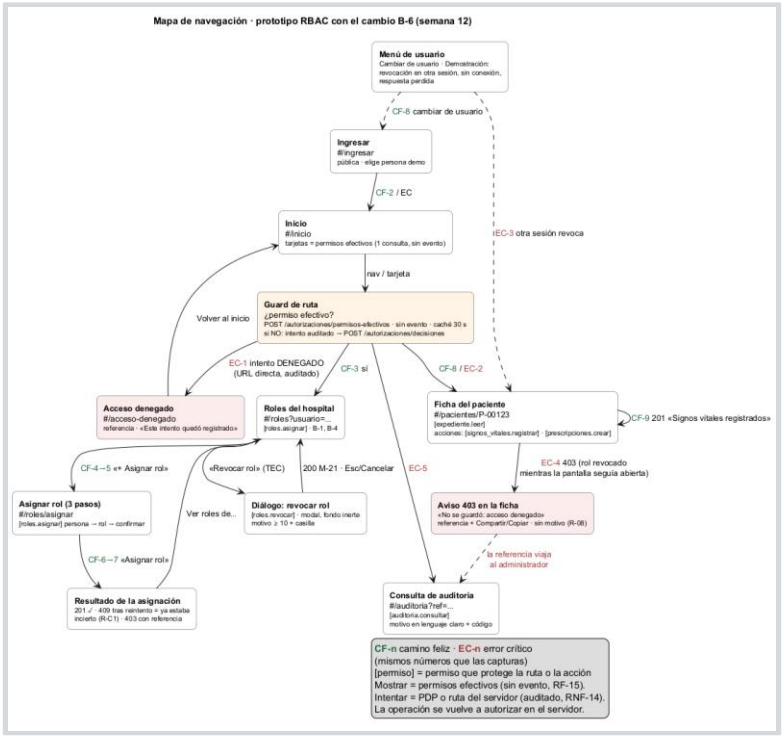




- **Breakpoints** 360 · 431 · 768 · 1024 (mobile-first)
- **Tabla → tarjetas** y diálogo → hoja inferior
- **Sin red:** no se autoriza ni se encolan cambios de permisos
- **Reintento medido:** asignar con fecha de fin NO es seguro (R-C1)

RNF-12, RNF-13 · D-26, D-27, D-28

Demostración: camino feliz y error crítico



Camino feliz

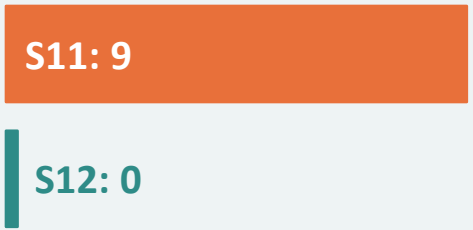
Carlos busca a Luis por nombre → asigna Enfermería (201 + referencia) → Luis ve «Pacientes» y registra signos (201). Bitácora: 0 denegaciones.

Error crítico

Ana entra a #/roles por URL → denegado + referencia. Abre la ficha; otra sesión le revoca el rol; pulsa Guardar → el servidor re-autoriza → 403 sin motivo. Carlos pega la referencia → «rol no vigente».

Cambio: denegaciones que nadie intentó

Denegaciones «fantasma» solo navegando



misma navegación, 4 personas

- **Pasivo (qué mostrar):** POST /autorizaciones/permisos-efectivos, sin evento (RF-15)
- **Activo (intentar):** PDP o ruta protegida, auditado como siempre (RNF-14)
- **Misma política** que el PDP: 42 combinaciones coinciden (PEF-03)
- **Rojo → verde:** 9 fallan → guardas API-01 y ARQ-08 → 80 pruebas, 0 fallan

Costo medido: AutorizacionControlador Ce 7 → 10, Ce medio 2.47 → 2.49, sin tocar Dominio, puertos ni adaptadores. Contrato v1.1.0 → v1.2.0 (solo agrega). Paridad 38/38 comparando también los eventos de la bitácora tras cada paso.

Matriz decisión → RF/RNF → evidencia

Decisión	Requisito	Evidencia
La interfaz no decide	RF-05, RNF-01	EC-4: 403 con el botón visible
403 sin motivo + referencia	RF-08, RNF-04, RNF-10	Recorrido EC-4 / EC-5
Confirmar con nombre y permisos	RF-01, RF-03	CF-6
Diálogo destructivo accesible	RF-11, RNF-11	TEC-1, TEC-2 (teclado)
Mobile-first, una sola app	RNF-12	16 pantallas móviles, 0 fallas
Reintento solo si es seguro	RNF-13	reintento.php (S10)
Permisos efectivos (cambio)	RF-15, RNF-14	PEF-01..10 · ruido 9 → 0

Matriz completa (D-18 a D-32): semana-12/matriz-decision-rf-rnf-evidencia.md · Pendiente: lector de pantalla real, backend por red (B-1, B-4, B-5).